

What if one weak piece of code could stop your entire deployment pipeline?

SonarLint Vs SonarQube

SonarLint

- IDE extension for:
- VS Code
- IntelliJ
- Eclipse
- Provides:
- Real-time code analysis
- Instant developer feedback
- Works locally while writing code

SonarQube

- Centralized platform/server for:
- Code quality analysis
- Security analysis
- Team-wide inspection
- Used in:
- CI/CD pipelines
- Enterprise workflows
- Provides:
- Dashboards
- Reports
- Quality Gates

SonarLint + SonarQube Workflow

- Developer writes code
- SonarLint detects issues instantly in IDE
- Code pushed to repository
- SonarQube performs enterprise-level scanning
- Quality Gate decides:
 - Pass
 - Fail

What is SonarQube?

- Platform for continuous:
- Code quality analysis
- Security analysis
- Static Application Security Testing (SAST)
- Scans source code before deployment
- Helps enforce secure coding standards

Why SonarQube is Used in Industry?

- Detects issues early in development
- Improves: Security, Reliability
- Maintainability
- Reduces:
- Technical debt & Production risks
- Commonly integrated with:
- GitHub, GitLab, Jenkins & CI/CD pipelines

What SonarQube Detects?

- Bugs
- Vulnerabilities
- Code Smells
- Duplicated code
- Security Hotspots

Quality Gates

- Automated rules deciding:
- Build Pass & Build Fail
- Based on:
- Vulnerability severity
- Code coverage
- Bug count
- Maintainability score

Important Terminologies

- Bug
- Vulnerability
- Code Smell
- Technical Debt
- Security Hotspot

SonarQube in DevSecOps

- Security becomes part of development workflow
- Developers receive feedback before production
- Enables:
 - Shift Left Security
 - Continuous Inspection
 - Automated Security Enforcement

Typical Workflow

Real-World Importance